

Incident Response Plan: Secure Cloud Banking Infrastructure with Cybersecurity & Compliance Framework on AWS

Introduction

The Incident Response Plan is created to handle security incidents in the cloud banking application hosted on AWS. The main goal is to reduce damage, recover services quickly, and protect customer data during cyber attacks or security issues.

The plan follows security standards like:

- ISO 27001
- NIST Cyber Security Framework

Main AWS Services Used

The following AWS services are used for security and monitoring:

- Amazon EC2
- Amazon S3
- AWS IAM
- AWS KMS
- AWS CloudTrail
- Amazon CloudWatch
- AWS GuardDuty
- AWS Security Hub
- AWS WAF
- Amazon RDS
- VPC

Incident Severity Levels

Incidents are divided into four levels:

Severity Meaning

- | | |
|----|--------------------------------|
| P0 | Critical attack or data breach |
| P1 | High security risk |
| P2 | Medium suspicious activity |
| P3 | Low-risk or false alert |

Incident Handling Process

1. Detection

The system continuously monitors cloud activities using:

- CloudWatch
- GuardDuty
- CloudTrail
- Security Hub
- WAF Logs

If suspicious activity is found:

- Alerts are generated
- SOC team is notified
- Incident ticket is created

Examples:

- Unauthorized login attempts
- Public S3 bucket exposure
- Malware detection
- DDoS attack

2. Analysis

The security team investigates:

- Which AWS resource is affected
- Which user or IP caused the issue
- How much impact occurred
- Whether the alert is real or false

AWS CLI commands and CloudTrail logs are used for investigation.

3. Containment

The affected resources are isolated immediately.

Examples:

- Blocking malicious IP addresses
- Disabling compromised IAM users
- Isolating EC2 instances using Security Groups
- Blocking suspicious traffic using WAF
- Rotating secrets and passwords

Goal:

- Stop the attack from spreading

4. Eradication

The root cause is removed completely.

Examples:

- Remove malware
- Delete malicious IAM users
- Patch vulnerabilities
- Replace compromised EC2 instances
- Remove backdoors

5. Recovery

The cloud environment is restored safely.

Examples:

- Restore database from backup
- Launch new clean EC2 instances
- Restore S3 objects using versioning
- Re-enable applications and services

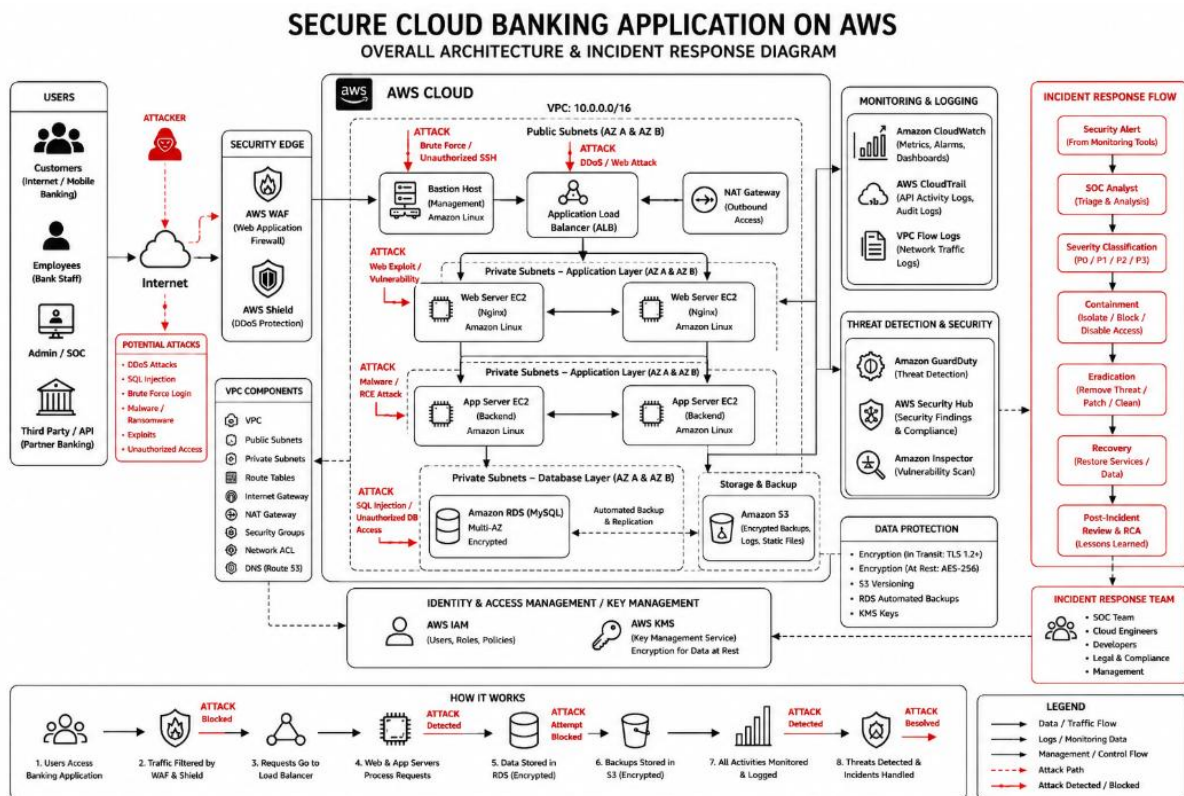
Monitoring is increased after recovery.

6. Post-Incident Activity

After the incident:

- Root Cause Analysis (RCA) is prepared
- Lessons learned meeting is conducted
- Security policies are improved
- New monitoring rules are added.

MAIN ARCHITECTURE ON INCIDENT RESPONSE PLAN:



Example Incident Handling

Example 1 — Compromised IAM Access Key

Steps:

1. Detect suspicious login using GuardDuty
2. Disable compromised access key
3. Rotate secrets and passwords
4. Check CloudTrail logs
5. Create RCA report

Example 2 — EC2 Malware Attack

Steps:

1. Isolate EC2 instance
2. Create forensic snapshot

3. Terminate compromised instance
4. Launch new EC2 from secure AMI
5. Patch vulnerabilities

Example 3 — Public S3 Bucket Exposure

Steps:

1. Detect public access
2. Block public permissions
3. Verify data exposure
4. Check access logs
5. Enable encryption and versioning

Conclusion

This Incident Response Plan helps the organization quickly detect and respond to cyber attacks in the AWS cloud environment. The plan improves cloud security, reduces downtime, protects sensitive banking data, and ensures compliance with industry security standards.